

Diagnostic module — defect report

Negative testing of OPD Investigation Entry and Sample Collection — 76 cases across billing, discounts, payment, patient details, packages and sample collection

HIS ERP — Medinova Medical Services Ltd. · <https://202.4.101.118:1115> · 19/09/2026, 21:06:01

Summary

- The most serious findings share one cause. Several numeric fields — DISC(%), DISC(Tk), Payment (cash) and the age boxes — do not refuse input they cannot read. They strip the characters they do not understand and use whatever digits are left. A minus sign disappears, so -300 becomes a 300 taka discount. A decimal point disappears, so 33.33 becomes 3333, which is over the limit, so the screen grants the largest discount it can instead. In every case the mistake costs the hospital money, and in most of them nothing is said.
- The discount controls have no authorisation behind them. D. Category is an ordinary editable box: any operator can type any category for any patient, with no employee or corporate mapping required. One of those categories, Special Discount, grants a full 100%. Between them, any bill can be written off to zero unaided. Clearing the form then leaves the category reading "General Discount" rather than N/A, so the next patient starts out discounted.
- Neither screen tells the operator when nothing was found. A search that matched nothing, a date range that was never valid, and a genuinely empty day all look identical: a grid that silently goes blank.
- Much of the rest holds up well, and is listed as such. Payment (cash) refuses decimals, overpayments and absurd figures cleanly — the very inputs that wreck the discount boxes beside it, which suggests the right validation already exists in the codebase and simply has not been applied to them. Card and mobile payments cannot be entered without choosing a type first. A SQL injection string and a script tag were both handled safely. Net payable is calculated, never editable, and its arithmetic closed exactly in every combination tried.

Defects (14)

SC_N_02

An impossible date is silently changed to a different one

HIGH

Sample Collection — /diagnostic/sample-collection

STEPS

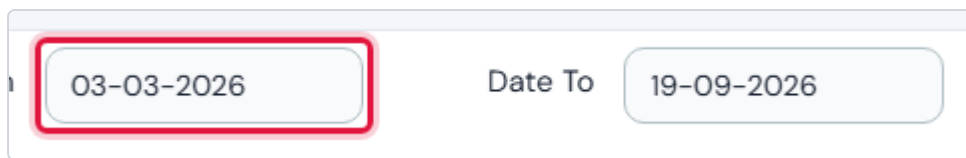
1. Click Date From
2. Type 31-02-2026
3. Press Enter

EXPECTED

The field refuses the date, or flags it — 31 February does not exist.

ACTUAL

The picker rolls the date forward and the field ends up holding 03-03-2026. The operator is now looking at a different day from the one they typed, with nothing on screen to say so.



A screenshot of a date picker interface. It features two input fields. The first field, labeled 'Date From', contains the text '03-03-2026' and is highlighted with a red rectangular border. The second field, labeled 'Date To', contains the text '19-09-2026'. The text 'Date To' is positioned between the two fields.

31-02-2026 was typed; the field holds 03-03-2026

Recording: bug-report/recordings/SC_N_02.webm

The defect as it happens — a still of the aftermath does not show it

TC-52 / TC-53 / TC-69 **A minus sign is dropped, turning an invalid entry into a real discount or payment** **HIGH**

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Load a patient (UHID 260900485302) and add one chargeable test
2. Set D. Category to General Discount
3. Type -300 into DISC(Tk)

EXPECTED

The entry is refused with a validation message; the bill is untouched.

ACTUAL

The minus is discarded and the digits behind it are applied — -300 becomes a 300 taka discount, and the bill drops accordingly. No message is shown at all. The same happens in DISC(%) (-10 grants 10%) and in Payment (cash) (-500 records a 500 taka payment), so an operator who mistypes a sign hands out money.

Sub total 1,490

Discountable(Tk) 1,400

D. CATEGORY

General Discount x

DISC(%) DISC(TK)

0 0

Net payable 1,490

Before: no discount, the full amount is owed

Sub total	1,490
Discountable(Tk)	1,400
D. CATEGORY	
General Discount	
DISC(%)	DISC(TK)
21	300
Net payable	1,190

After typing -300: the box holds 300 and the discount has been applied

Recording: [bug-report/recordings/TC-52-TC-53-TC-69.webm](#)

The defect as it happens — a still of the aftermath does not show it

TC-55b / TC-56 / TC-63 A decimal point or comma is dropped, so a mistyped discount becomes the largest one allowed HIGH

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Load a patient (UHID 260900485302) and add one chargeable test
2. Set D. Category to General Discount
3. Type 33.33 into DISC(%)

EXPECTED

Either the fractional percentage is applied, or the entry is refused as not a valid number.

ACTUAL

The point is discarded, leaving 3333, which is over the category ceiling — so the screen grants the maximum instead, 50%. "1,000" and "10.5.5" do the same. A slip of the keyboard is the difference between no discount and the largest one the operator is allowed to give.

The screenshot shows a form with the following fields and values:

Sub total	1,490
Discountable(Tk)	1,400
D. CATEGORY	
General Discount	
DISC(%)	0
DISC(TK)	0
Net payable	1,490

Before: nothing discounted

The screenshot shows the same form as above, but with the following changes:

Sub total	1,490
Discountable(Tk)	1,400
D. CATEGORY	
General Discount	
DISC(%)	50
DISC(TK)	700
Net payable	790

After typing 33.33: the box holds 50 — the ceiling, not the figure asked for

Recording: [bug-report/recordings/TC-55b-TC-56-TC-63.webm](#)

The defect as it happens — a still of the aftermath does not show it

TC-07 / TC-78 Any operator can pick any discount category, and one of them clears the bill entirely **HIGH**

OPD Investigation Entry — [/diagnostic/investigation](#)

STEPS

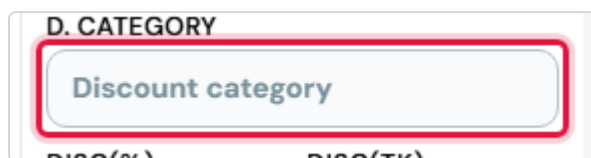
1. Click the D. Category box (it reads N/A)
2. Type a category name and take it from the list — no employee number or mapping is needed
3. Choose Special Discount and set DISC(%) to 100

EXPECTED

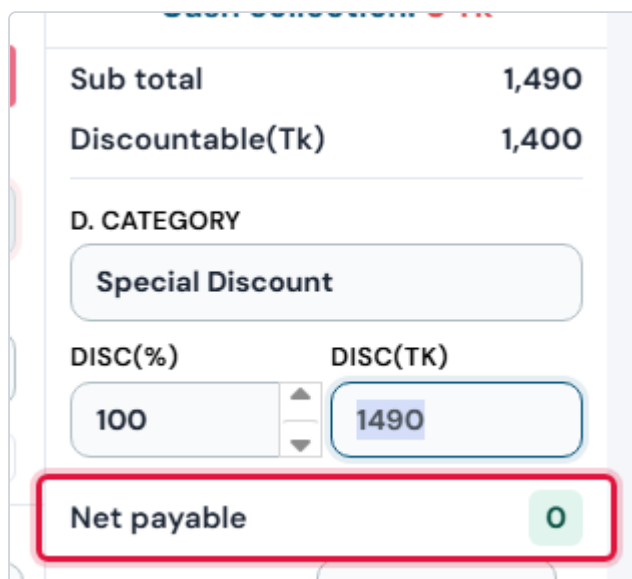
The category comes from the patient record — an employee or corporate mapping — and cannot be set by hand; a discount that clears a bill needs approval.

ACTUAL

The box is an ordinary editable field: arbitrary text can be typed into it, and any of the four real categories can be chosen for a walk-in patient with no entitlement. Special Discount grants a full 100%, taking Net payable to zero. Together these let any operator write off any bill unaided. (Every Staff Discount invoice raised while testing went to a walk-in patient with no employee number.)



Arbitrary text typed straight into the category box: ""



Special Discount at 100% — Net payable is now zero

SC_N_01 A reversed date range is accepted in silence **MEDIUM**

Sample Collection — /diagnostic/sample-collection

STEPS

1. Set Date From to 19-09-2026
2. Set Date To to 10-09-2026 (earlier than From)
3. Press Show

EXPECTED

The range is refused with a message such as "Date To must be on or after Date From", and no query is sent.

ACTUAL

No message appears. The query runs and the grid empties, which reads to the operator as "there are no invoices today" rather than "your dates are the wrong way round".

The screenshot shows the 'Sample Collection' interface. At the top, there is a search bar and a 'Date From' field set to '19-09-2026' and a 'Date To' field set to '10-09-2026'. A 'Show' button is next to the date fields. Below the date fields, there are radio buttons for 'New Patient' (selected), 'Collected Patient', and 'Partial Collected', and a link for 'All Patient'. To the right, there is a 'Sample collection at' dropdown menu set to 'HUB'. Below these controls is a table with the following headers: INVOICE NO, NAME, GENDER, CABIN NO, REF DOCTOR NAME, DATE, TIME, and BILL NO. The table body is empty.

Date From 19-09-2026, Date To 10-09-2026 — the grid is empty and nothing is said

Recording: [bug-report/recordings/SC_N_01.webm](#)

The defect as it happens — a still of the aftermath does not show it

SC_N_03

Both dates can be cleared and Show still runs

MEDIUM

Sample Collection — /diagnostic/sample-collection

STEPS

1. Clear Date From
2. Clear Date To
3. Press Show

EXPECTED

A "date is required" message; Show does not fire.

ACTUAL

Both fields sit empty, Show fires anyway, and the grid comes back blank with no explanation.

The screenshot shows a web form for 'Sample Collection'. At the top, there's a search bar and a breadcrumb trail '/diagnostic/sample-collection'. Below this, there are two date input fields labeled 'Date From' and 'Date To', both containing the placeholder text 'DD-MM-YYYY'. These fields are highlighted with red boxes. To the right of the 'Date To' field is a blue 'Show' button. Further right is a dropdown menu labeled 'Sample collection at' with 'HUB' selected. Below these fields are four radio buttons: 'New Patient' (selected), 'Collected Patient', 'Partial Collected', and 'All Patient'. At the bottom of the form is a table with the following headers: 'INVOICE NO', 'NAME', 'GENDER', 'CABIN NO', 'REF DOCTOR NAME', 'DATE', 'TIME', and 'BILL.NO'. The table body is currently empty.

Both date fields empty after pressing Show

Recording: [bug-report/recordings/SC_N_03.webm](#)

The defect as it happens — a still of the aftermath does not show it

TC-10 Clearing the form leaves a discount category behind for the next patient

MEDIUM

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Load a patient (UHID 260900485302) and add a test
2. Press the red X beside Search to clear the form

EXPECTED

Everything returns to its starting state, D. Category included — back to N/A.

ACTUAL

The patient, the grid and the totals all clear properly, but D. Category comes back reading "General Discount" — the first entry in the list — instead of N/A. The next patient billed on that form starts out entitled to a discount nobody granted them, and nothing on screen says so.

FULL NAME	AGE (Y-M-D)	DATE OF BIRTH	GENDER	MOBILE NO	D. CATEGORY
RAFIQUL ISLAM	36 4 5	14-05-1990	Male	01727412621	N/A

Before the reset: a patient is loaded and the category reads N/A

FULL NAME	AGE (Y-M-D)	DATE OF BIRTH	GENDER	MOBILE NO	D. CATEGORY
Patient name	0 0 0		Select	Mobile No	General Discount

After the reset: the patient is gone but the category reads "General Discount"

Recording: bug-report/recordings/TC-10.webm

The defect as it happens — a still of the aftermath does not show it

TC-18 Gender is drawn as a required field but never enforced**MEDIUM**

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Open a fresh form and press POST
2. Fill in the name, mobile number, age and referring doctor, leaving Gender on "Select"
3. Press POST again

EXPECTED

POST is refused until a gender is chosen, as the red border implies.

ACTUAL

Gender is given the red border of a missing mandatory field, but nothing checks it. POST works through name, mobile, age and doctor in turn and then asks for the test grid — it never once mentions gender, so an invoice can be raised for a patient with none recorded.

FULL NAME	AGE (Y-M-D)	DATE OF BIRTH	GENDER	MOBILE NO
TEST PATIENT	30 0 0	19-09-1996	Select	01700000001

Name, mobile and age all filled; Gender left on "Select" and POST went past it

TC-16 The mobile number is never checked for shape**MEDIUM**

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Enter a name
2. Type 12345 into Mobile No
3. Press POST

EXPECTED

"Invalid mobile number format" — a Bangladeshi mobile number is eleven digits.

ACTUAL

Five digits are accepted, and so are fourteen. POST passes straight over the field and goes on to ask about the age instead, so a bill can be raised against a number nobody can be reached on.

FULL NAME	AGE (Y-M-D)	DATE OF BIRTH	GENDER	MOBILE NO
TEST PATIENT	0 0 0		Select	12345

Mobile No holds "12345" and POST has moved on to its next complaint

TC-19c / TC-20 / TC-21b Age accepts impossible values and silently wraps others**MEDIUM**

OPD Investigation Entry — /diagnostic/investigation

STEPS

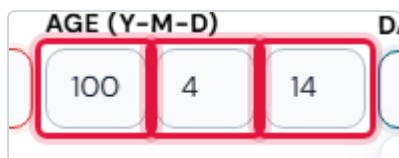
1. Type 999 into the age Y box
2. Type 15 into M
3. Type 45 into D

EXPECTED

Each is refused: nobody is 999 years old, months run 0–11 and days 0–30.

ACTUAL

999 years is taken as it stands. 15 months silently becomes 3 and 45 days becomes 14 — the values wrap rather than being refused, so the record ends up holding an age nobody typed. Typing 2.5 gives 25, the same dropped-decimal behaviour as the discount boxes.

A screenshot of a form titled 'AGE (Y-M-D)' with three input boxes. The first box contains '100', the second '4', and the third '14'. The boxes are highlighted with a red border.

Typed 999 / 15 / 45 — the boxes hold 999 / 3 / 14

SC_N_04 / SC_N_05 An empty result is never explained **LOW**

Sample Collection — /diagnostic/sample-collection

STEPS

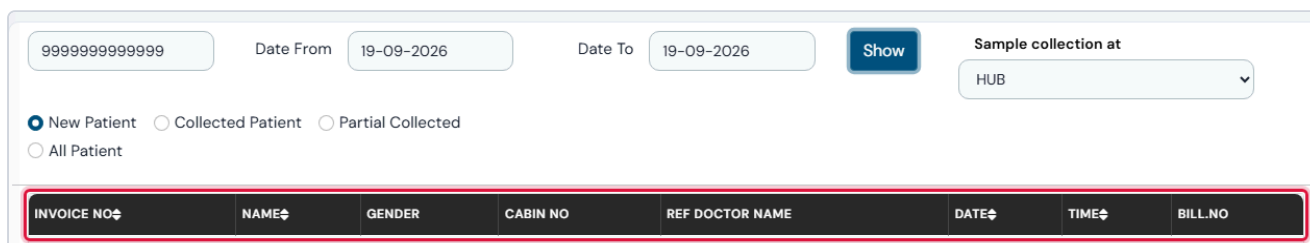
1. Type 99999999999999 into the search box
2. Press Show

EXPECTED

The grid shows "No record found" or similar.

ACTUAL

Both grids simply go blank. The same blank grid appears for a future date range, for a reversed range and for a genuinely empty day, so it carries no information at all.

A screenshot of a 'Sample Collection' form. The search box contains '99999999999999'. The 'Date From' and 'Date To' fields are both set to '19-09-2026'. The 'Show' button is highlighted. Below the search fields, there are radio buttons for 'New Patient' (selected), 'Collected Patient', 'Partial Collected', and 'All Patient'. To the right, there is a dropdown menu for 'Sample collection at' with 'HUB' selected. At the bottom, there is a table with columns: INVOICE NO, NAME, GENDER, CABIN NO, REF DOCTOR NAME, DATE, TIME, and BILL NO. The table is currently empty.

An invoice number that cannot exist — both grids blank, no message

SC_N_10 The search box has no maximum length **LOW**

Sample Collection — /diagnostic/sample-collection

STEPS

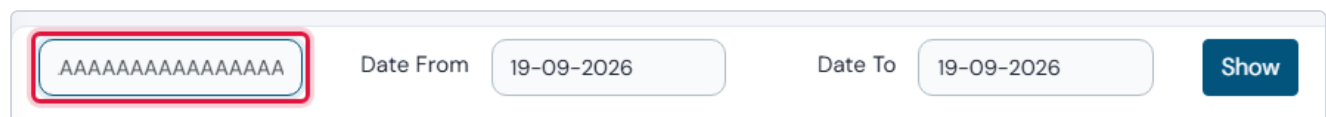
1. Paste 600 characters into the search box

EXPECTED

The field caps the input at a sensible length — an invoice number is 13 digits.

ACTUAL

All 600 characters are accepted and sent. No injection got through in testing, but a field with no ceiling is a payload surface that costs nothing to close.



600 characters pasted; the field holds all 600

TC-13 The patient name field has no maximum length **LOW**

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Paste 300 characters into Full Name

EXPECTED

The field caps the input at a sensible length.

ACTUAL

All 300 characters are kept. The same gap exists in the search box on Sample Collection.



300 characters pasted; the field holds 300

TC-49 A package can be taken apart line by line LOW

OPD Investigation Entry — /diagnostic/investigation

STEPS

1. Choose the OPD package "Hungary Medical"
2. Delete one of the lines it put on the bill

EXPECTED

A component of a package cannot be removed on its own, or removing it is at least remarked on.

ACTUAL

Any line can be deleted, package component or not, and the bill simply gets cheaper by that amount. Nothing in the grid marks a line as belonging to a package, so there is no way for an operator to tell which lines came as a set. Whether packages should be splittable at all is a product decision.

SL	NAME	D.DATE	D.TIME	QTY	RATE	DISC(%)	NOTE	G.TK	URGENT	
1	URINE ANALYSIS R/M/E	09/20/2026	02:59 PM	1	225	0		225	☐	
2	X-RAY CHEST -P/A VIEW (DIGITAL)	09/20/2026	02:59 PM	1	375	0		375	☐	
3	BLOOD SUGAR - RANDOM	09/20/2026	02:59 PM	1	150	0		150	☐	
4	HBSAG-ELISA METHOD	09/20/2026	02:59 PM	1	525	0		525	☐	
5	SERUM CREATININE	09/20/2026	02:59 PM	1	325	0		325	☐	
6	ANTI-HAV IGM	09/20/2026	02:59 PM	1	1,050	0		1,050	☐	
7	SGPT (ALT)	09/20/2026	02:59 PM	1	375	0		375	☐	

The package on the bill

Sub total6,075

Discountable(Tk)0

D. CATEGORY

N/A

DISC(%)DISC(TK)

00

Net payable6,075

One component deleted — the bill is simply smaller, with nothing said

Behaved correctly

SC_N_02b	A loose date format (19/09/26) is understood and normalised to 19-09-2026.
SC_N_11	Print Token with no invoice selected answers "Please select Investigation Invoice." and prints nothing.
SC_N_12	Print Label with no invoice selected answers the same, and prints nothing.
SC_N_06	A whitespace-only search is handled like an empty one; no error.
SC_N_07	Special characters (!@#\$%^&*()) are handled without a server error.
SC_N_08	A SQL injection string (' OR 1=1--) returns nothing and causes no database error.
SC_N_09	A script tag is rendered as text; it neither executes nor reaches the DOM as markup.
SC_N_13	A collected test cannot be collected again. It drops out of the "New Patient" list entirely, and though it keeps a checkbox under "Collected Patient", that one selects labels to reprint — ticking those rows and pressing Print Label leaves every status exactly as it was.
SC_N_18	Double-clicking Print Token leaves the screen working.
SC_N_19	Changing the patient filter refreshes the grid without pressing Show.
SC_N_21	A six-year date range answers rather than hanging.
SC_N_22	Selecting a second patient clears the first one's tests.
SC_N_24	A test with no tube mapping renders a blank cell, not "null".
TC-01 / TC-64	Sub total and Net payable are calculated spans, not fields; they cannot be typed into.
TC-02	Rewriting Sub total in the DOM changes nothing — there is no field behind it to submit.
TC-03 / TC-67	Emptying the grid takes the totals back to zero; removing a line recalculates at once.
TC-04	Discountable never exceeds Sub total; a government-fixed-rate test is not discountable at all.
TC-06	A large bill is shown in full, grouped with separators, and is not clipped by its column.
TC-08	A discount is refused while D. Category is N/A, with a reason given.
TC-11 / TC-14 / TC-15	A blank, whitespace-only or missing name and a blank mobile all stop the post.
TC-12	A symbol in a patient name is called out, naming the character and the rule.

TC-22 / TC-23	A future date of birth is refused, and date of birth and age stay in step with each other.
TC-24	One press of POST flags every missing field at once.
TC-46 / TC-48 / TC-50	A missing package offers nothing; a test already in the package is not charged twice; a second package replaces the first rather than stacking.
TC-51 / TC-54 / TC-60 / TC-61	Discounts over the ceiling, over the bill, or against nothing discountable are all refused with a message.
TC-57	Leading zeros are normalised — 0010 is read as ten.
TC-58 / TC-66	The two discount boxes stay in step, and Net payable is exactly Sub total less the discount.
TC-68 / TC-72 / TC-73 / TC-74	Payment refuses an overpayment, a payment against an empty bill, paisa, and an absurd figure.
TC-76 / TC-77	Card and mobile amounts cannot be entered at all until a card type or an operator is chosen.
TC-79	Cash and card together cannot overpay the bill.

Not covered by this run

SC_N_14	Two operators collecting the same lab number at once — needs a second session collecting a live sample.
SC_N_15	A role without permission — test-data holds a password only for the Administrator account.
SC_N_16	Session timeout — the session runs about eight hours; needs a build with a shorter one.
SC_N_17	Network loss mid-collection — would leave live data in a partial state.
SC_N_20	Browser Back after a collection — needs a real collection to go back from.
SC_N_23	A cancelled invoice — cancelling one needs a two-step approval and leaves a cancelled bill on the ledger.
TC-09	A patient arriving with a discount category already mapped — every patient this suite creates is a walk-in with no employee number, and the screen offers no way to find one that has a mapping.
TC-62 / TC-71 / TC-75 / TC-80	Anything that needs a bill actually posted: editing a discount or payment afterwards, and whether a bill with nothing paid is refused. Each would put a real invoice on the live ledger. Worth running against a test database.
TC-02b	Posting a bill with the total tampered in the DOM — same reason. TC-02 shows what can be established without it: there is no field behind the figure for a tamperer to submit.

Also worth knowing

Two kinds of feedback, and one of them disappears

The print buttons on this screen put their refusal inline, beside the button, where it stays — which is the right way round. Most other outcomes across the diagnostic screens, though, are reported only through a snackbar that shows and hides again in about a second. A refused invoice post, for instance, answers "Staff Hospital discount: due amount must be fully paid." and then takes it away, leaving the form untouched; an operator who looked away sees a screen that simply did not respond. Automating those screens meant installing a recorder in the page to catch the messages at all. The inline style used by the print buttons would serve the rest of the application better.

Wording

"Succesfully Fetched!" (missing an s) appears on sample collection, and "Could not found printer." on both the investigation and sample screens. The second is also misleading: it is shown after a save that succeeded, so it reads as a failure when only the printing failed.

Server availability during testing

The application refused connections on port 1115 three times during one afternoon of testing, each outage lasting from a few minutes to over a quarter of an hour. Runs in progress failed with `ERR_CONNECTION_REFUSED`. Not a defect in the screen under test, but it made several results inconclusive and is worth looking into separately.